

Datasäkerhetsanalys: Hemtjänsten i Gedehamn

Soltani, Ahmad (ahmso698)

November 24, 2025

Abstract

The healthcare company Hemtjänsten Gedehamn has recently introduced a digital system that allows the company to monitor whether carers have completed their tasks. However, the stored data is not adequately protected from unauthorized access. This report analyzes the potential risks and threats that endanger the data stored by the company, using the CIA analysis method. Additionally, the report discusses measures that can help the company prevent or minimize data leaks and identifies the best strategies to secure their system against vulnerabilities.

Contents

1	Inledning	3
1.1	Syfte	3
1.2	Frågeställningar	3
2	Metod	3
3	Hotagenter	4
3.1	Identity Authentication Failure	4
3.2	SQL Injection	4
3.3	Session Management Failure	4
3.4	Insiderhot	5
4	Riskanalys	5
5	Åtgärder och Kostnadsanalys	6
5.1	Åtgärd (A):	6
5.2	Kostnadsanalys (A):	6
5.3	Åtgärd (B):	6
5.4	Kostnadsanalys (B):	6
5.5	Åtgärd (C):	6
5.6	Kostnadsanalys (C):	7
5.7	Åtgärd (D):	7
5.8	Kostnadsanalys (D):	7
6	Referenser	7

1 Inledning

Datasäkerhet är ett viktigt koncept inom webb-baserade applikationer och används för att skydda känslig data. En webb-baserad applikation är en mjukvarulösning med varierande funktionalitet som körs på klientens enhet för att tillhandahålla specifika webbtjänster. Med tanke på den snabba ökningen av internetanvändning publiceras enorma mängder data på nätet, och dessa data behöver skyddas från obehöriga.

1.1 Syfte

Syftet med uppsatsen är att genomföra en datasäkerhetsanalys av det nyligen lanserade systemet för hemtjänsten i Gedehamn. Efter att riskerna har analyserats är målet att föreslå de bästa och mest kostnadseffektiva åtgärderna. Detta syftar dels till att minska riskerna och dels till att hantera potentiella skadestånd.

1.2 Frågeställningar

1. Vad händer med säkerheten?
2. Finns det en risk att data försvinner när den behövs som mest?
3. Hur skyddas vårdtagares och assistenters personliga integritet?
4. Vad är risken för fortsatt fusk?
5. Hur kan en handikappanpassad, säker signering av utförda uppgifter garanteras utan hjälp av fuskande assistenter?
6. Hur mycket tid tas från vården för att hantera datorsystemet om det är för klumpigt?

2 Metod

För att skriva denna uppsats har jag använt mig av både föreläsningsmaterial och kurslitteratur. Jag har valt CIA-modellen för att ge läsaren en förståelse av hur olika hot påverkar användare av webb-baserade applikationer. För att tydliggöra innehållet i uppsatsen kommer jag att använda tabeller och räkneformler som presenteras i kursboken och föreläsningarna.

3 Hotagenter

Under denna del av uppsatsen presenteras de hotagenter som är mest relevanta för systemet inom hemtjänsten, inklusive riskanalys samt förslag på bästa åtgärder. Hotagenterna granskas även utifrån principerna enligt CIA-modellen (Confidentiality, Integrity, Availability).

3.1 Identity Authentication Failure

Detta hot handlar om processen att verifiera användarens identitet inom ett system. Det finns olika metoder för att verifiera sig, exempelvis via lösenord, fingeravtryck, ansiktsgenkänning osv. När en användare registrerar sig i systemet, genereras en token (en krypteringsnyckel eller ett krypterat lösenord) som används för att verifiera användaren vid inloggning. Ett verifieringsmisslyckande, kallat "Identity Authentication Failure", innebär att användarens verifieringsuppgifter inte överensstämmer med de som registrerats i systemet.

Ett hot relaterat till detta är användandet av svaga och lättgissade lösenord och användarnamn (poor validation). Ett annat relevant hot är attacker där angriparen använder metoden "man-in-the-middle" för att fånga den genererade token som används vid inloggning. Dessa hot skapar stor oro för användarna, då deras känsliga data kan missbrukas av angripare, eller så kan deras åtkomst till systemet blockeras.

3.2 SQL Injection

SQL Injection är ett av de mest förekommande och farligaste hoten mot webbaserade tjänster. Angriparen kan genomföra attacken genom att generera skadlig SQL-kod för att få tillgång till känsliga data som lagras på databasservern. Denna data kan omfatta vårdtagares medicinska status, bankuppgifter, kontaktinformation till anhöriga eller information om personal.

Enligt CIA-modellen kan en SQL Injection-attack få flera konsekvenser. Exempelvis kan befintlig data raderas eller manipuleras, såsom vårdtagarens vårdplan eller personalens arbetsschema (integritet). En oönskad schemaändring kan leda till att varken vårdcentralen eller nästa personal som tar över arbetet får korrekt information om vårdtagarens status (tillgänglighet).

SQL Injection är särskilt relevant för hemtjänsten, eftersom systemets databas behöver uppdateras kontinuerligt. Exempel på detta är när en ny brukare ska läggas till eller tas bort från systemet, eller när anhörigas kontaktuppgifter behöver uppdateras.

3.3 Session Management Failure

En session är en sekvens av HTTP-förfrågningar och svar som skickas mellan användaren och webapplikationen när användaren är inloggad i systemet. Varje gång en användare loggar in skapas en session med ett unikt session-ID, som lagras i tillfälliga session-cookies. Detta gör det enklare för användaren att förbli inloggad tills sessionen avslutas eller session-ID:t går ut.

Angripare kan använda olika metoder som sessionsfixering, sessionssniffning eller cross-site scripting (XSS) för att stjäla användarnas session-ID. Den vanligaste metoden är XSS, där angriparen injicerar ett skadligt skript som hämtar session-cookies inklusive session-ID.

Utifrån CIA-modellen skapar dessa hot en osäker användarupplevelse och kan leda till stöld av känslig information. Även om detta hot inte är lika relevant som andra hot, kan det fortfarande

utgöra en risk, särskilt eftersom användare som inte är tekniskt kunniga kan råka klicka på länkar eller köra skript som skadar systemet.

3.4 Insiderhot

Ett insiderhot innebär att personer med behörighet och tillgång till resurser utnyttjar dessa för att skada organisationen. I hemtjänstens fall kan detta inkludera anställda eller vårdtagares anhöriga som har tillgång till brukarnas handdatorer.

- **Outbildad personal:** Personal som saknar utbildning kan oavsiktligt orsaka skada genom att inte hantera patienternas information korrekt.
- **Stöld av enheter:** Stöld eller borttappade handdatorer kan skapa stora problem då användaren förlorar tillgång till verktyget för att rapportera personalens arbete till vårdcentralen.
- **Utsatt målgrupp:** Eftersom brukarna ofta är äldre med synnedsättning, hörselnedsättning eller demenssjukdom, är de extra sårbara för personal som försöker lura dem att signera falska arbetsuppgifter eller logga in i deras bankkonton för att stjäla pengar eller bankuppgifter.

Insiderhot är mycket relevanta inom hemtjänsten eftersom anställda har direktkontakt med brukarna under sitt arbetspass och tillgång till verksamhetens resurser.

4 Riskanalys

Under denna del presenteras en beskrivning av de risker som det nya systemet kan medföra i hemtjänsten. En riskanalys i form av en tabell visar hur allvarlig varje risk är.

- **A (Högt):** Hög risk för fortsatt fusk av personal trots det nya systemet, Oskyldig personal kan drabbas av fusket.
- **B(Mellan):** Känslig information om både brukare och personal läcker ut. Detta är troligt eftersom både insiderhot och nätangrepp utgör potentiella risker. Dock bedöms detta vara hanterbart eftersom hemtjänsten är en kommunal verksamhet, där det ofta finns relativt bra back-up-system för känsliga data.
- **C(Lågt):** Ekonomiska kostnader för verksamheten. Detta inkluderar kostnader för implementeringen av systemet samt integrering av det i den dagliga verksamheten.
- **D(Jätte lågt):** Brukarna riskerar att bli av med pengar. Det finns en risk att personal lurar brukarna att överföra pengar, eller att deras bankuppgifter blir föremål för nätangrepp.

Konsekvens	Nästan omöjligt	Möjlig	Trolig	Oundviklig
Försumbar	-		-	-
Hanterbar	D(0,01)	-	C(0,6)	-
Allvarlig	-	B(0,4)	A(0,75)	-
Katastrofal	-	-	-	-

Table 1: Riskanalys för Hemtjänsten i Gedehamn

5 Åtgärder och Kostnadsanalys

Under denna delen av uppsatsen presenteras de åtgärder som kan hjälpa Hemtjänsten i Gedehamn att ta de bästa och lönsamma besluten. I analysen används grund formeln : för att räkna de kostnaderna utan några åtgärder($r = p \cdot d$) och med åtgärder ($r' + k = p' \cdot d + k$), där $d=1$. Valutan för kostnaderna är fiktiv och baseras på antagandet att den representerar miljontals kronor.

5.1 Åtgärd (A):

Införandet av mellanchefer som kontrollerar de genomförda arbetsuppgifterna vid passbyten. Denna åtgärd minskar risken från allvarlig till hanterbar ($P' = 0,6$) .

5.2 Kostnadsanalys (A):

Dock ökar kostnaderna för hemtjänsten genom lönehöjningar eller nyanställningar ($k = 1.5$)

- **Utan åtgärd:** Hög risk kvarstår, vilket kan leda till oönskade konsekvenser och minskad effektivitet i verksamheten. $r = 0.75 \cdot 1 = 0.75$
- **Med åtgärd:** Kostnaden för införandet av mellanchefer kompenseras genom förbättrad kontroll och minskad risk för ineffektivitet. $r' + k = 0.6 \cdot 1 + 1.5 = 2.1$

5.3 Åtgärd (B):

1. Utbildning av personal för att undvika att klicka på länkar med okänt innehåll. Detta kan minska sannolikheten för insiderhot från "Hanterbar $\times$ Trolig" till "Hanterbar $\times$ Möjlig" ($P' = 0.45$). 2. Minska risken för nätangrepp genom implementering av stark systemkonfiguration och verifiering, vilket förhindrar gissningsbara lösenord och användarnamn ($P' = 0.4$).

5.4 Kostnadsanalys (B):

1. Kostnader för att arrangera möten och bjuda in experter som kan utbilda personalen ($k = 2$).
2. Administrativa kostnader och ökade arbetsuppgifter för IT-avdelningen ($k = 3$).

- **Utan åtgärd:** Riskerna för insiderhot och nätangrepp kvarstår, vilket kan leda till allvarliga konsekvenser.
1: $r = 0.45 \cdot 1 = 0.45$
2: $r' + k = 0.3 \cdot 1 + 2 = 2.3$ (lönsamt)
- **Med åtgärd:** Utbildning och systemförbättringar minskar risken för säkerhetsincidenter avsevärt.
1: $r = 0.45 \cdot 1 = 0.45$
2: $r' + k = 0.3 \cdot 1 + 3 = 3.3$ (Hyfsat lönsamt)

5.5 Åtgärd (C):

För att minimera risken för systemkrasch kan hemtjänsten i Gedehamn genomföra regelbundna säkerhetskontroller och ha back-up-system vid uppdateringar. Detta minskar risken för systemkrasch till ($P' = 0.2$).

5.6 Kostnadsanalys (C):

Att anlita säkerhetsexperter för att analysera och identifiera potentiella systemrisker medför en kostnad ($k = 2.5$).

- **Utan åtgärd:** Hög risk för systemkrasch, vilket kan störa verksamheten.
 $r = 0.6 * 1 = 0.6$
- **Med åtgärd:** Förbättrad systemstabilitet och färre avbrott i verksamheten.
 $r'+k = 0.2 * 1 + 2.5 = 2.7$ (lönsamt)

5.7 Åtgärd (D):

Att skydda brukarnas känsliga data på nätet minimerar risken för oönskade penningöverföringar från deras bankkonton. Föreslagna åtgärder inkluderar ($P'=0.05$):

- Kryptering av session-ID.
- Automatisk utloggning när brukaren är inaktiv.

5.8 Kostnadsanalys (D):

Detta medför inte stora kostnader ($k=0.2$).

- **Utan åtgärd:** Brukarna löper hög risk att förlora pengar eller få sina bankuppgifter stulna.
 $r = 0.1 * 1 = 0.1$
- **Med åtgärd:** Kostnaden för implementering av kryptering och automatisk utloggning vägs upp av ökad datasäkerhet och trygghet för brukarna.
 $r'+k = 0.05 * 1 + 0.2 = 0.25$ (Jätte lönsamt)

6 Referenser

- 1: Stallings, W., Brown, L. (2018). Computer Security: Principles and Practice (4:e upplagan). Pearson
- 2: Föreläsningar